

MANUAL DE CONSUMO EPS FAMILIAR DE COLOMBIA API

La API permite la autenticación de usuarios y la gestión de afiliados mediante el uso de los endpoints REST.

Alcance y URL base

La URL base depende del despliegue <https://api.familiardecolombia.com>. Todos los paths de este manual son relativos a esa base.

Documentación interactiva: GET /docs (Swagger UI), GET /redoc (ReDoc), GET /openapi.json (OpenAPI 3) - <https://api.familiardecolombia.com/docs>.

Autenticación JWT

Login (público, sin Bearer)

Método y ruta: POST /auth/login

Content-Type: application/json

Cuerpo ejemplo: {"username": "<usuario>", "password": "<contraseña>"}

Respuesta 200: objeto con access_token (JWT) y expires_in (segundos).

Respuesta 401: credenciales inválidas o usuario inactivo.

La contraseña se encuentra almacenada como hash SHA-256 (hex 64 caracteres).

Peticiones protegidas

Incluir en cada solicitud (excepto POST /auth/login):

Authorization: Bearer <access_token>

Si el token falta, es inválido o expiró, la API responde 401.

Autorización

Lista blanca por endpoint para usuarios que no son administradores, solo se permiten las rutas definidas allí, comparando método HTTP (ej. POST, GET, PUT) y la ruta del endpoint tal como se registra (incluye parámetros de ruta en forma de plantilla, por ejemplo /agendamientos/{id_agendamento}). Si el usuario no tiene ninguna regla, no se bloquea por lista blanca.

Catálogo de endpoints

La tabla resume método, ruta, si requiere JWT y notas. Los cuerpos y respuestas detallados están en /openapi.json y en /docs.

Método	Ruta	JWT	Notas
POST	/auth/login	No	Emite token
POST	/consultas/afiliado	Sí	Consulta afiliada por documento; nit_ips opcional
POST	/dispensacion	Sí	JSON Version_12.0
POST	/agendamientos	Sí	Crear cita; valida afiliado activo
PUT	/agendamientos/{id_agendamiento}	Sí	Actualiza estado del agendamiento
POST	/historia_clinica	Sí	JSON Version_12.0

Códigos de respuesta habituales

- 200/201: éxito según operación.
- 400: validación de negocio o datos.
- 401: token ausente/inválido o login fallido.
- 403: sin permiso de módulo/acción o sin autorización en seg.usuario_endpoints.
- 404: recurso no encontrado (ej. afiliado, agendamiento).
- 409: conflicto (ej. cita duplicada en agendamiento).
- 422: error de validación de esquema (Pydantic).
- 500: error interno.
- 502/503: fallas de servicios externos (ej. SIIFA) o, en algunos casos, imposibilidad de leer seg.* para permisos (503 con mensaje operativo).

Trazas y auditoría

Los intentos de login se registran, las muchas operaciones de negocio registran consumo con detalle JSON (servicio lógico, usuario, documento cuando aplica, resultado, http_status).